Walkthrough — halloween secret note

Concise, step-by-step CTF walkthrough

Challenge Name: **halloween secret note** | Difficulty: **Hard** | Author: **Karthik**

Overview

This walkthrough documents the steps taken to find the flag in the **halloween secret note** challenge. The target is a small web application running locally at `http://127.0.0.1:5000/` .

Step 1 — Initial reconnaissance

1. Open the target in a browser: `http://127.0.0.1:5000/` .
2. The page shows a login form (username / password).

Step 2 — Directory enumeration to find username

Use a directory brute force tool (example uses `gobuster`) to enumerate the web root and discover hidden directories.

```
  # example command
gobuster dir -u http://127.0.0.1:5000/ -w /usr/share/wordlists/dirb/big.txt
```

The scan reveals `/about` (HTTP 200). Visiting `/about` shows a hint referencing *Jack Skellington*, which leads to the username:

- **Identified username:** `jackskellington`

Step 3 — Further enumeration to find password

Continue enumeration on the discovered directory to find additional hidden content.

```
  # scan the about directory
gobuster dir -u http://127.0.0.1:5000/about -w /usr/share/wordlists/dirb/big.txt
```

The scan reveals `/about/dark` (HTTP 200). Visiting `/about/dark` shows a dark page; viewing the page source or highlighting the content reveals a hidden string.

- **Identified password:** `pumpkinking`

Step 4 — Login and initial access

Use the discovered credentials on the main login page:

```
  Username: jackskellington
Password: pumpkinking
```

After a successful login you are redirected to `/dashboard?id=1` , which displays notes belonging to `jackskellington` .

Step 5 — Exploit IDOR to retrieve the flag

The `id` query parameter in `/dashboard?id=1` is not properly access-controlled (IDOR - Insecure Direct Object Reference). Modify the numeric ID to enumerate other users' notes.

1. Change the URL to use another id, for example: `/dashboard?id=6` .
2. Visit `http://127.0.0.1:5000/dashboard?id=6` .

The page displays secret notes that contain the flag.

> **Flag found:** `HAUNT{FLAG**********}`